01 / OVERVIEW

ClearDesk

HackerDNA / IDOR, API Security and Path Traversal

English edition
Visual presentation: COMMANDO. Based on the supplied walkthrough and its original evidence.

Lab information

Platform: HackerDNA **Difficulty:** Medium **Flags:** 2
Categories: IDOR, API Security, Path Traversal, Access Control and Privilege Escalation.
Lab: hackerdna.com/labs/cleardesk

Objective

Capture two flags: one accessible from a standard user account by exploiting IDOR, and another requiring administrator access to the application.

Reconnaissance with Nmap

Initial enumeration identified HTTP services on ports 80/TCP and 8080/TCP, running Nginx and Gunicorn respectively.

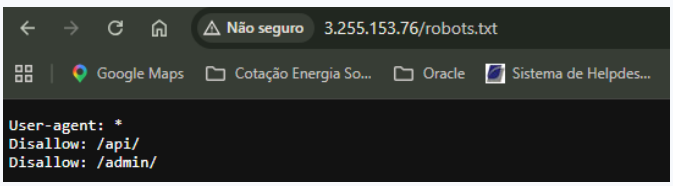
```
hacker:~$ nmap -sV 3.255.153.76
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-15 17:28 +0000
Nmap scan report for localhost (3.255.153.76)
Host is up (0.0000040s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
80/tcp   open  http    nginx 1.28.2
8080/tcp open  http    Gunicorn

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.52 seconds
hacker:~$
```

01. Service enumeration results from the lab environment.

What robots.txt revealed

The file exposed /api/ and /admin/. Although intended for web crawlers, these paths provided useful starting points for application enumeration.



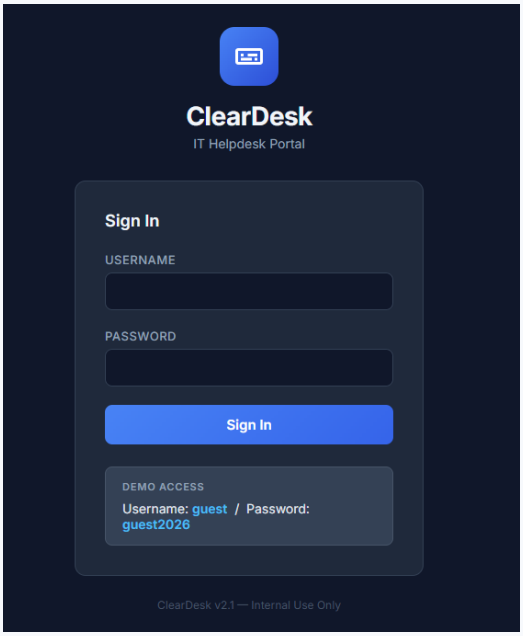
02. Application paths found in robots.txt.

02 / INITIAL ACCESS

The guest session

From the login form to the application dashboard

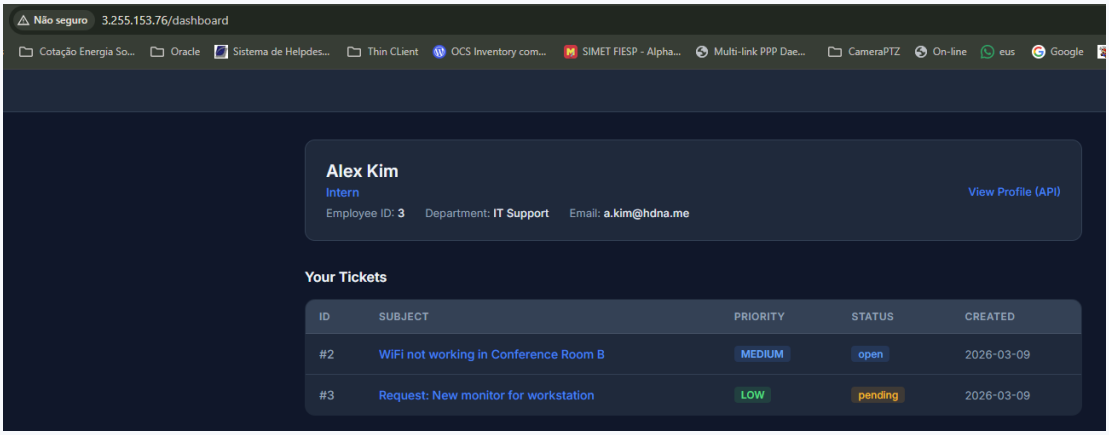
The guest credentials displayed on the login page provided access to the main application dashboard.



03. Login page showing the demonstration account.

Main dashboard

The initial session exposed the current user’s profile and support tickets. This access was then used to explore the API discovered through robots.txt.



04. Profile and tickets available to the guest account.

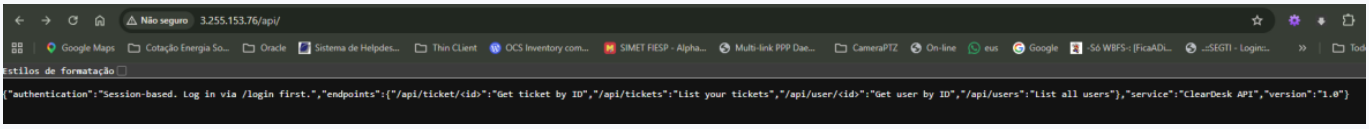
03 / ACCESS CONTROL

Exploiting IDOR

REST API / Profiles and tickets addressed by numeric identifiers

The API contained an Insecure Direct Object Reference (IDOR) vulnerability. Changing numeric identifiers allowed access to objects without adequate authorization checks.

API enumeration



05. API response observed during enumeration.

As a result, user information and tickets belonging to other accounts could be retrieved.

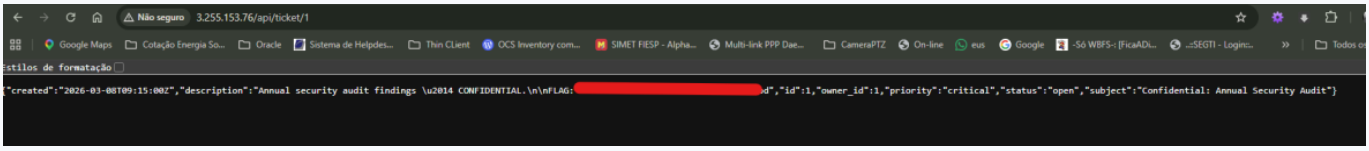


06. Evidence of accessing information through the API.

Retrieving the user flag

The first flag was obtained from ticket 1. The following address belongs to the instance documented in the original walkthrough.

```
http://3.255.153.76/api/ticket/1
```



07. Ticket containing the first flag, redacted in the original screenshot.

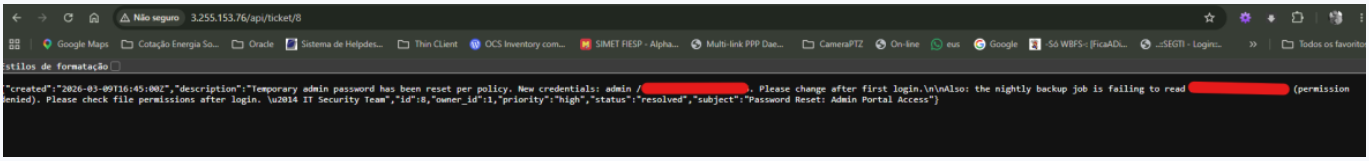
Reading note: IP addresses refer to the documented session. Redactions in the original images have been preserved.

04 / PRIVILEGE ESCALATION

Administrator access

Credentials exposed in a support ticket history

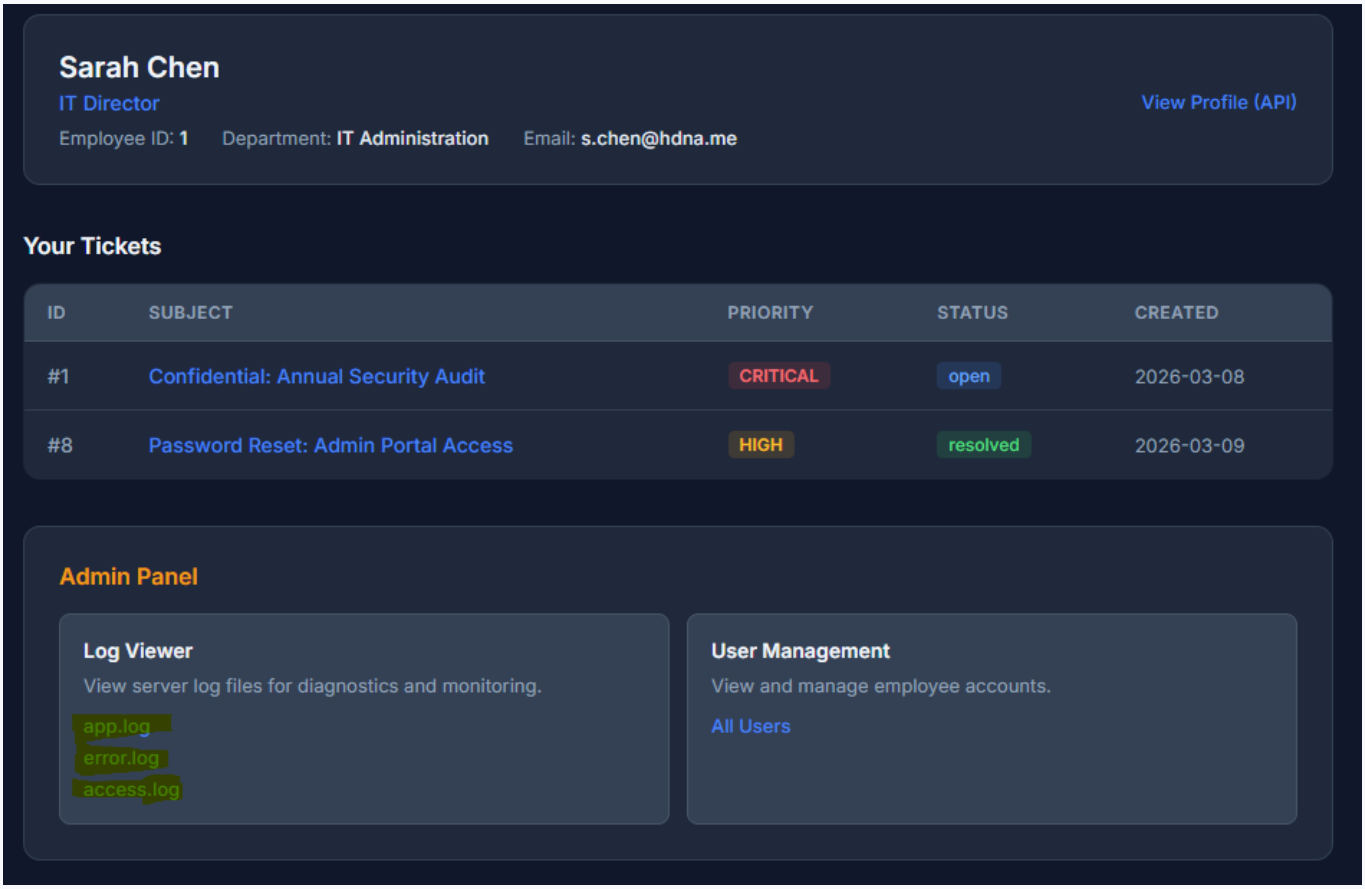
Reviewing tickets accessible through IDOR revealed a password-reset request for the administrator. Its history exposed sensitive information in plaintext, including the new login credential.



08. Password-reset ticket, retaining the original redactions.

Switching accounts

After signing out of the guest session, the disclosed administrator credentials were used to log in. The administrator dashboard included a console for viewing server log files.



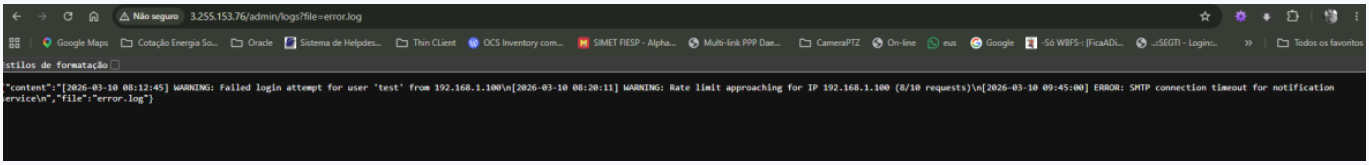
09. Administrator dashboard with Log Viewer and User Management features.

05 / FILE DISCLOSURE

LFI and Path Traversal

Manipulating the file requested by the log viewer

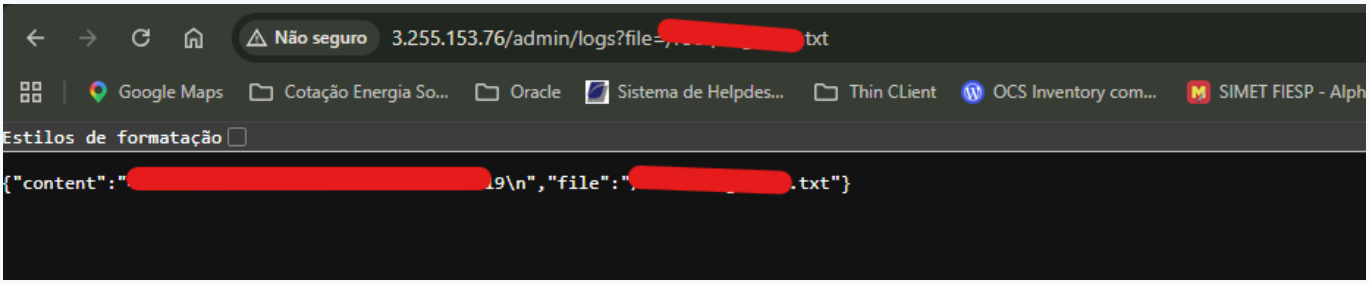
The administrator dashboard provided a log-viewing feature. Manipulating the file-selection parameter allowed operating-system files to be read, a weakness described as LFI in the supplied walkthrough.



10. Evidence of exploiting the file-reading functionality.

Retrieving the root flag

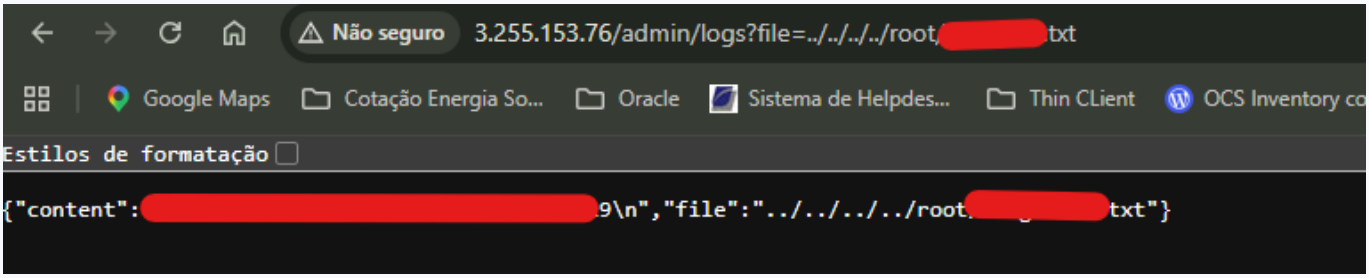
The vulnerability enabled the file containing the root flag to be read.



11. Root flag file response; its contents remain redacted as in the source.

Escaping the intended directory

The same mechanism accepted ../ sequences, demonstrating Path Traversal. This allowed navigation outside the directory intended by the application and access to sensitive system files.



12. Relative path used during the Path Traversal exploitation.

06 / LESSONS LEARNED

Conclusions and skills

From application enumeration to sensitive file disclosure

Conclusions

The lab demonstrates how separate weaknesses can be chained to compromise an application. Paths exposed through robots.txt aided enumeration, while IDOR enabled unauthorized access to sensitive records.

Those records revealed administrator credentials, leading to LFI and Directory Traversal exploitation against sensitive files. The exercise highlights the importance of API authorization, protecting information in support tickets, and enforcing access controls around system resources.

Skills demonstrated

• Web application reconnaissance and enumeration.

• REST API and access-control analysis.

• IDOR exploitation and investigation of exposed tickets.

• Privilege escalation through compromised administrator credentials.

• LFI and Path Traversal for file disclosure.

Lessons learned

Identify sensitive endpoints through enumeration; validate authorization for every object; protect information stored in support systems; apply least privilege; and restrict file access to explicitly permitted resources.

About this edition

Visual presentation: COMMANDO.
English adaptation of the supplied PDF, preserving all 12 original screenshots and their redactions. Screenshots remain in their original form. No new exploitation attempts were performed for this edition.